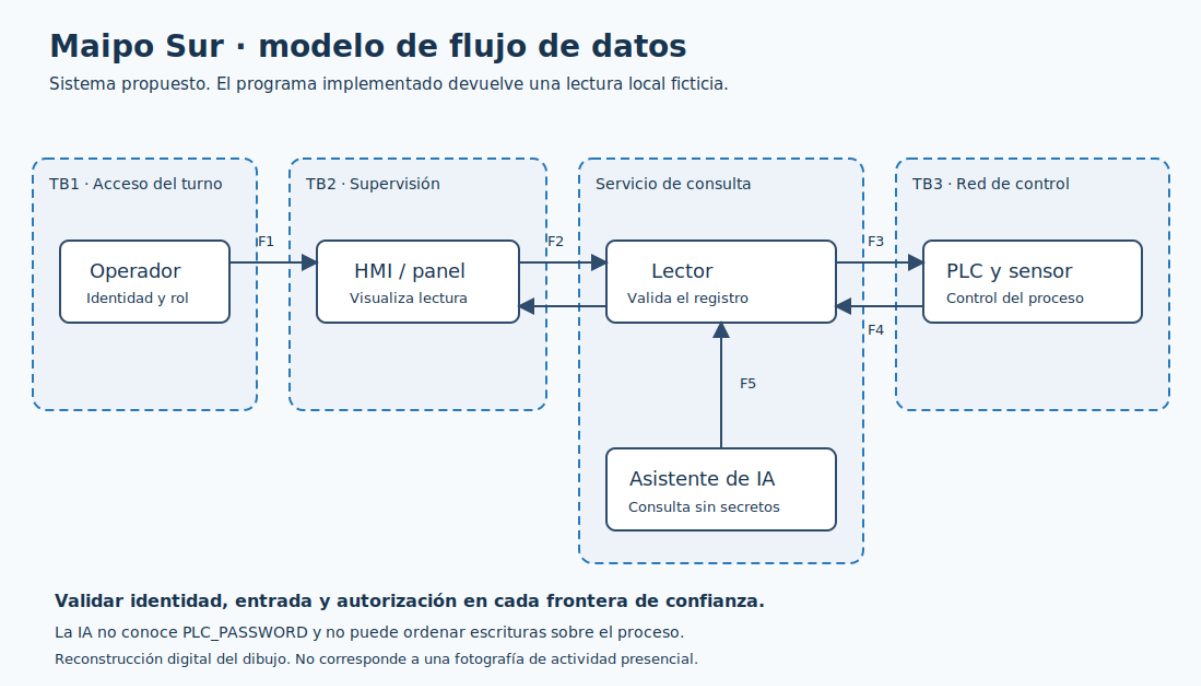
Maipo Sur: ficha de blindaje

SISTEMA AUTO DEVSECOPS LAB 1 · 14-10-2026

Miguel Briceño: desarrollo. **Franco Perez:** pipeline. **Marcela Manzor:** operación y auditoría IA. Roles propuestos para el trabajo grupal.

Sistema y dibujo

Planta de agua ficticia: lector local de cloro. Un cambio inseguro en una planta real podría alterar la supervisión del tratamiento. La implementación solo devuelve una lectura preparada y no controla equipos.



Tres amenazas y controles

Credencial expuesta (S/I): suplantación del turno y posible alteración del tratamiento. Gitleaks y variable de entorno; sustitución simulada comprobada; revocación antes de uso real.

Entrada convertida en comando (T/E): acciones indebidas con permisos del lector. Semgrep y validación; programa final sin shell.

Panel abierto (E/D): interrupción de acceso durante una falla. Trivy config y modelo de red limitado.

Controles, hallazgos y decisiones

Gitleaks, Semgrep, Trivy fs, OSV y Trivy config. Pruebas negativas y SBOM CycloneDX. La credencial del caso inicial se corrige en main; el defecto queda en una rama didáctica. Se rechaza el parche inseguro. Miguel, Franco y Marcela figuran como responsables propuestos, con revisión el 16-10-2026.

Parche de IA: rechazado técnicamente

Paquete: consulta PyPI HTTP 404, sin distribución verificable. Entrada: host y registro concatenados con shell=True. Protección: verify=False. Destino: TELEMETRIA no definido en el fragmento, envío no justificado. Evidencias: docs/auditoria-ia/veredicto.md y reports de Actions. Ratificación personal pendiente del grupo.

Explicación para operación

Este cambio podría permitir que una entrada manipulada ejecute órdenes con los permisos del lector y afectar la supervisión del tratamiento del agua. Además, enviaría las lecturas a un destino sin justificar y sin comprobar correctamente su certificado, por lo que rechazamos la propuesta hasta corregir esos riesgos.

Borrador asistido por IA, corregido sin inventar el destino de TELEMETRIA.

Reproducción, evidencia y pendientes

Ejecutar install_tools.py, instalar tools/requirements.lock y correr analizar.sh y pruebas_controles.py. Enlaces exactos y resultados en evidencias/VALIDACION.md. Antes de planta real: identidades, segmentación, pruebas de fabricante y rollback. Fotografía del dibujo: evidencias/diagrama-papel.jpg. Simulación: scripts/simular_rotacion.py e informe de Actions.